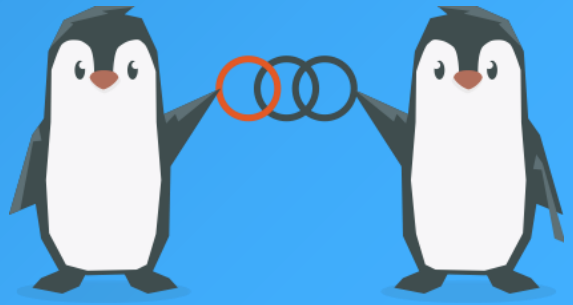
AGL Assessment Automation (AAA) Overview and Insights

Hiroyuki Ishii, Panasonic Automotive Systems | Linux Foundation Japan Evangelist

THE LINUX FOUNDATION

OPENCHAIN



Who ~~we are~~ I am

Takashi Ninjouji

- Chief Engineer, Honda Motor
- AGL, **Lead of this initiative**
- OpenChain, SPDX

Hiroyuki Ishii

- OSS Community Expert & Senior Architect, Panasonic Automotive Systems
- Linux Foundation Japan Evangelist
- AGL Steering Committee
- Kernel, Yocto, Tracing, Virtualization, OSPO

THE LINUX FOUNDATION

OPENCHAIN

Background: Why SBOM Matters in Automotive

Lerge-Scale Software Development

- Without automated SBOMs, it's extremely difficult to manage risks across all software components

Complex Supply Chains

- Common data format and shared practices are essential to manage multi-tier suppliers

Regulatory & Compliance *(not exhaustive)*

- UNECE WP.29 R155/R156, ISO/SAE 21434, US E.O. 14028, US BIS ICTS
- ISO/IEC 5230, ISO/IEC 18974

Automotive Grade Linux (AGL)

- Non-profit organization hosted at Linux Foundation
- Open source Linux-based collaborative project
- Unified Code Base (UCB): Open platform for automotive (IVI, cluster, telematics, …)
- Free to customize, no certification required (unlike Android)

AGL Assessment Automation (AAA)

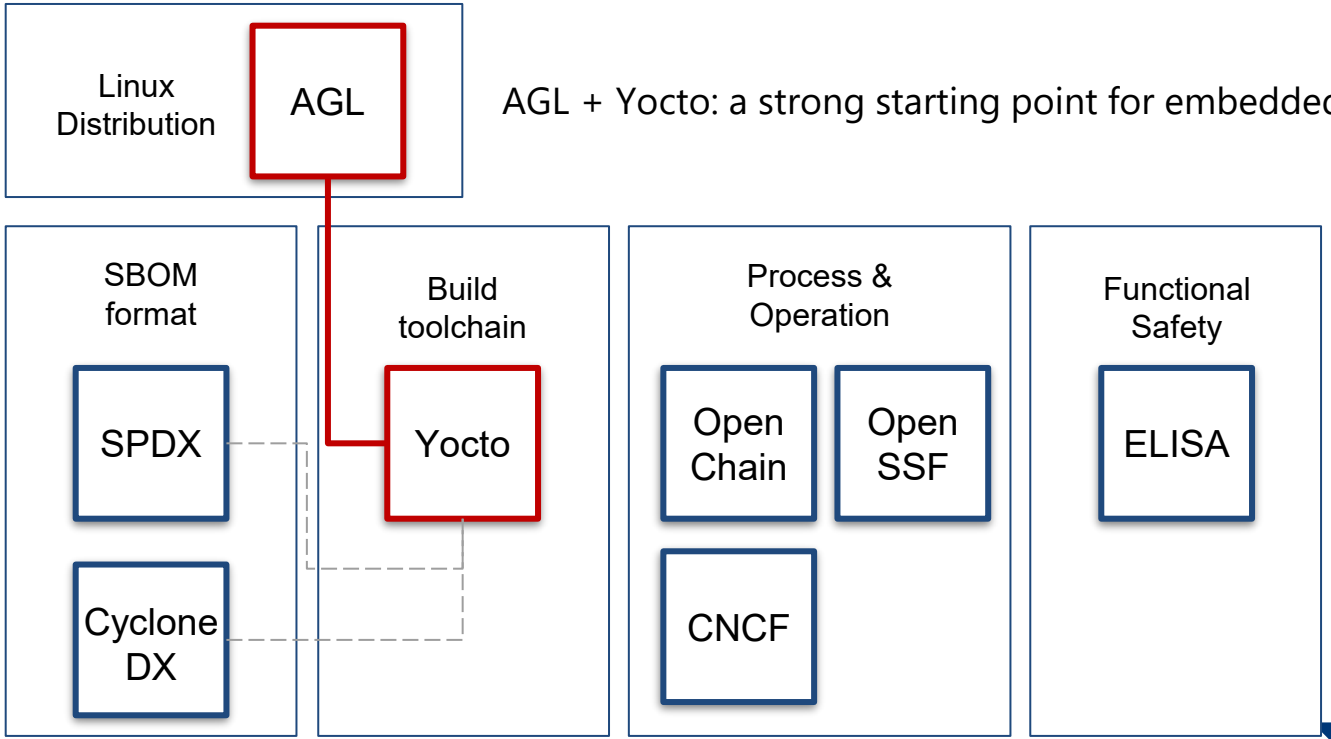
Purpose

- Build a reference system and share best practices for SBOM operations for Automotive and Embedded industries

Focus

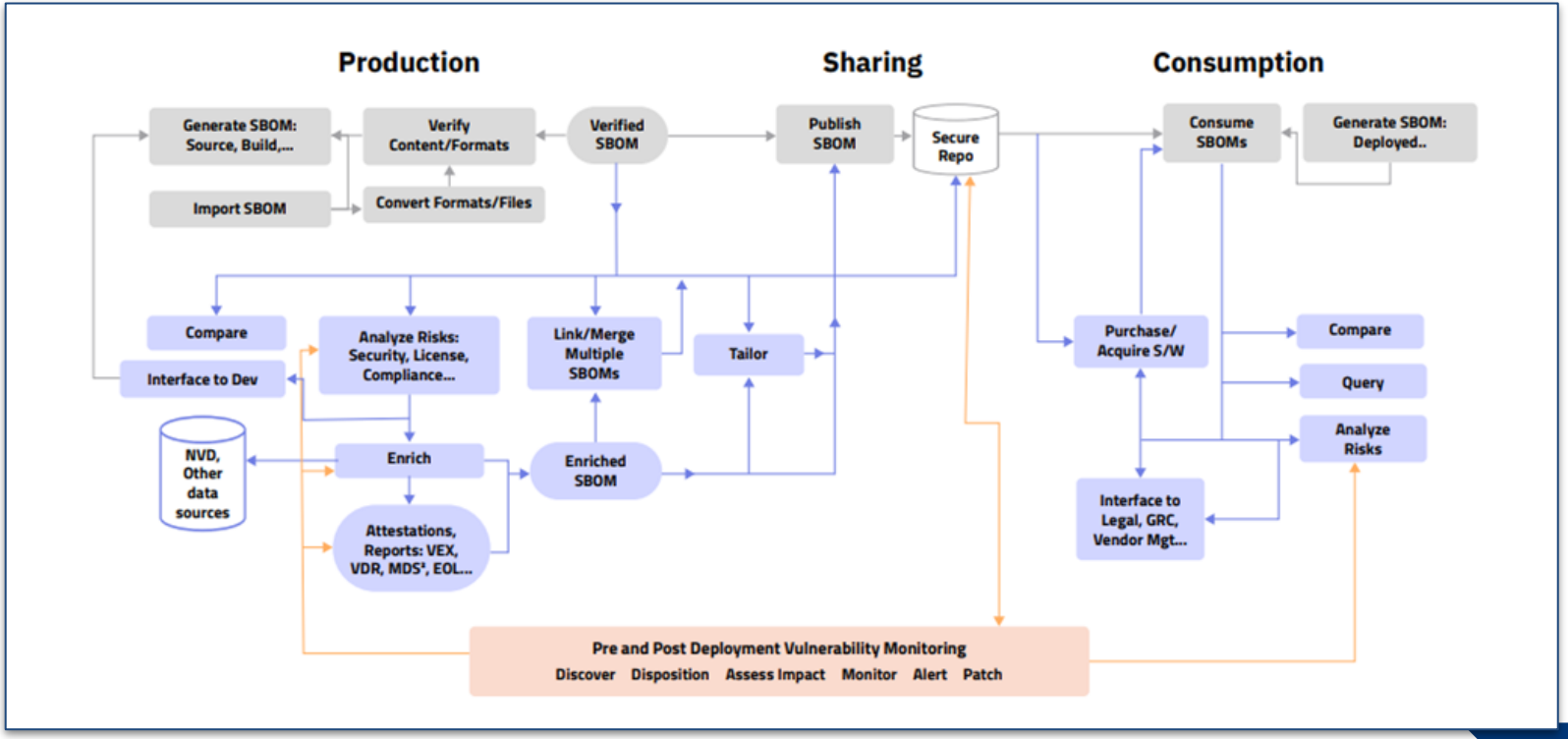
- **Validate policy-based assessment automation in the AGL CI system**
- Adopt cybersecurity best practices from OpenSSF and CNCF, as much as possible
  - SBOM Lifecycles, SLSA, …
- Targeting **SPDX 3.0** JSON (Yocto-compatible)
- Collaborate with OSS communities (e.g., Yocto, OpenSSF, OpenChain, SPDX)
- Leverage open-source, reusable toolchains

Explore Best Practices for SBOM Operations



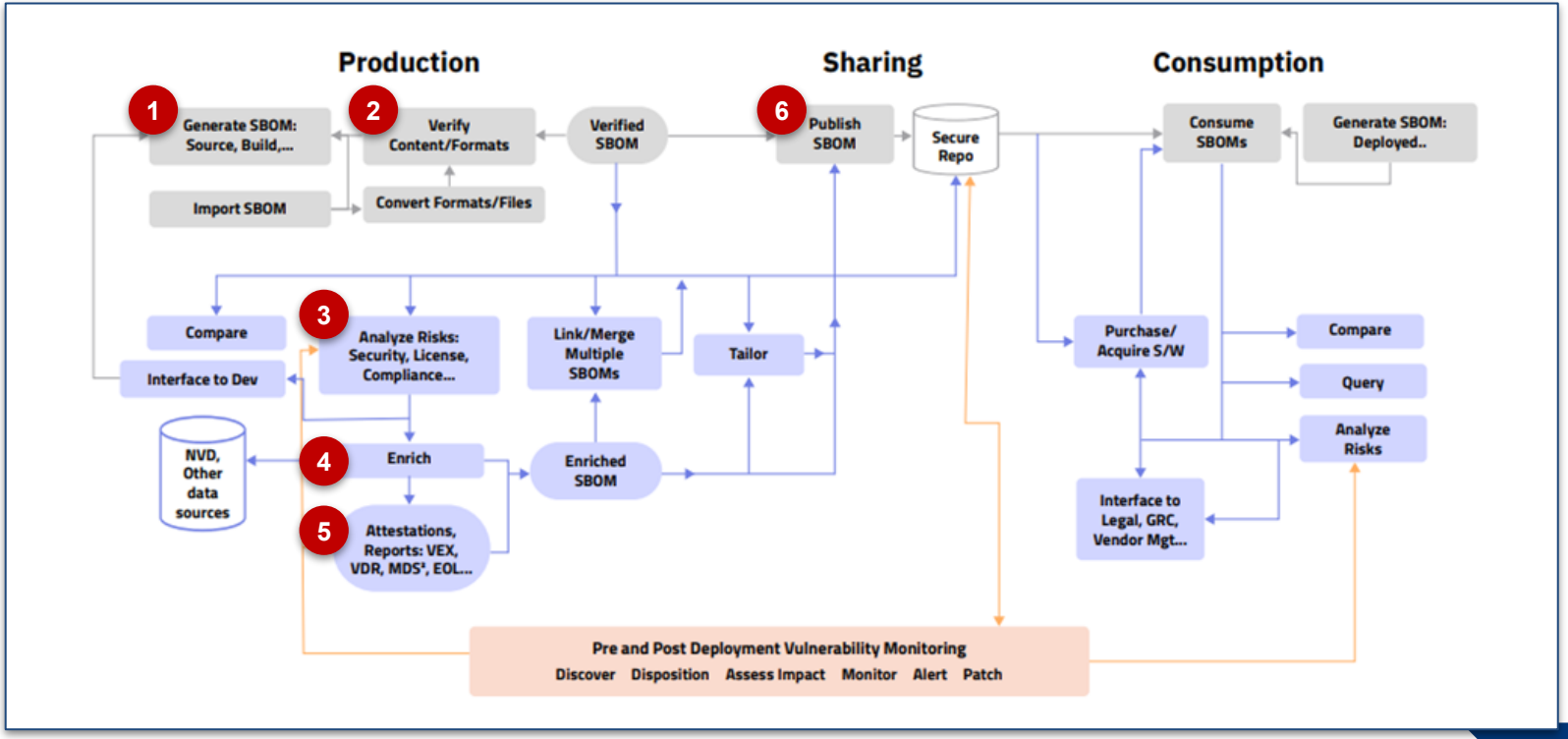
AGL + Yocto: a strong starting point for embedded SBOM

Automating Processes Aligned with the SBOM Lifecycle



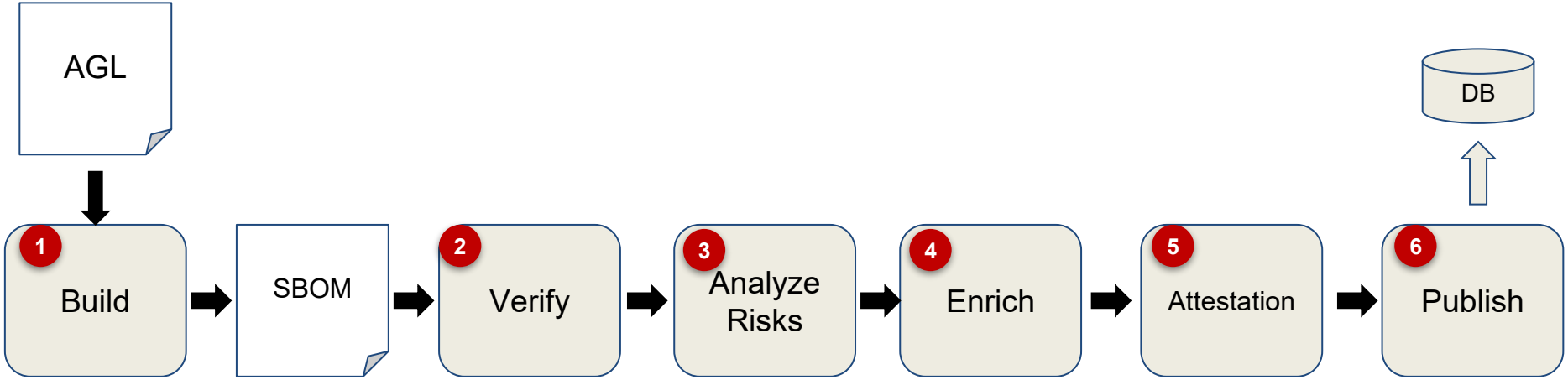
Source: OpenSSF. Improving Risk Management Decisions with SBOM Data.

Starting with Best-Case Implementation Examples

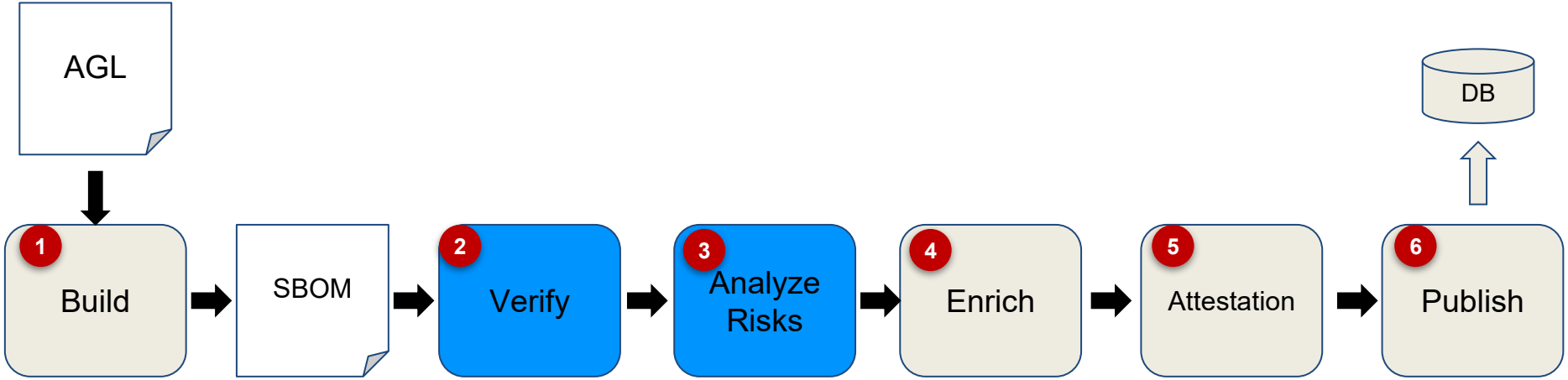


Source: OpenSSF. Improving Risk Management Decisions with SBOM Data.

Pipeline Example



Pipeline Example



PoC: Verify

Limited availability of validation tools for SPDX 3.0 (as of January 2026)

➞ As a result, we implemented a simple validator as a PoC

Tool	SPDX Spec version	Profile / Scope
Telco SBOM Validator	SPDX 2.2, 2.3	OpenChain Telco SBOM Guide 1.1
NTIA conformance checker	SPDX 2.2, 2.3, 3.0	NTIA 2021, FSCT3 (minimum)
Sbomqs	SPDX 2.2, 2.3	BSI TR-03183-2 (v1.1 & v2.0), FSCT v3, OpenChain Telco, NTIA

PoC: Verify

Validated Yocto SPDX 3 SBOMs generated from AGL UCB

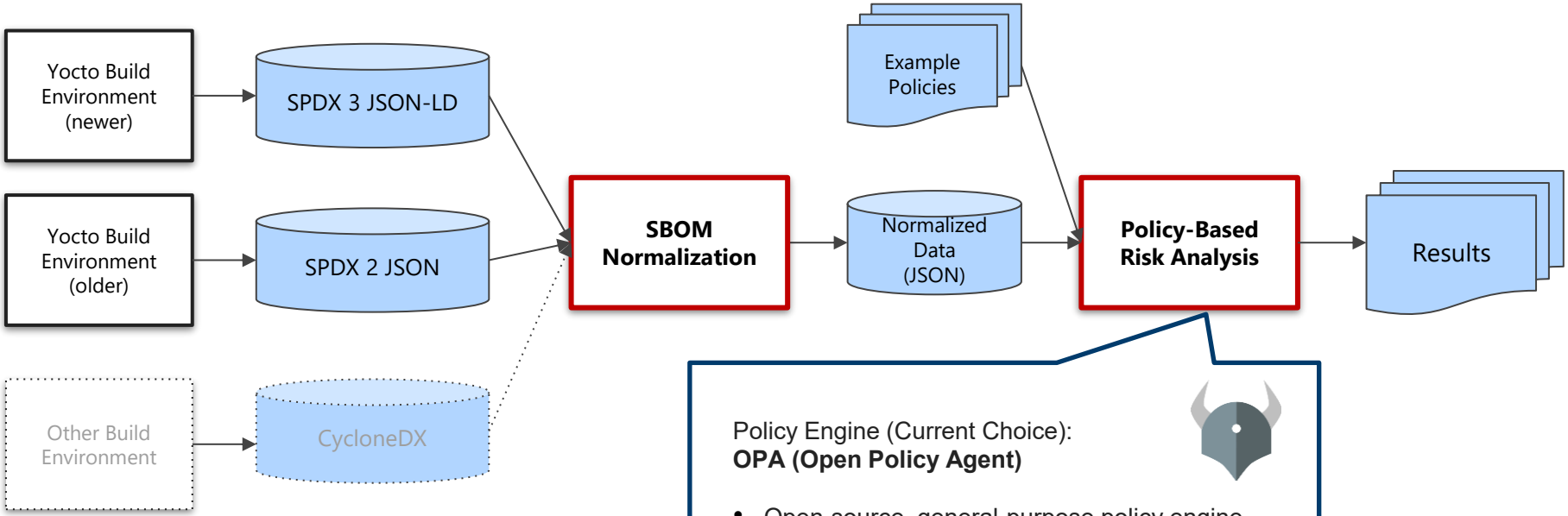
- Overall quality is already good (based on OpenChain Telco SBOM Guide)
- Further improvements are ongoing in the Yocto community (e.g., PURL)

```
 python3 spdx_tree_viewer.py /home/ubu/depot/automation-playground/examp
le-sboms/spdx3.0/agl-image-minimal-qemux86-64.rootfs-20251125004622.spdx
.json --scope-summary
======================================================================
LifecycleScopedRelationship Summary by Scope
======================================================================

Total LifecycleScopedRelationships: 2860
Scopes: 2

----------------------------------------------------------------------
Scope                    Rels   Packages      Files
----------------------------------------------------------------------
build                    2537        452        630
runtime                   323        205          0
----------------------------------------------------------------------
```

```
Requirements Summary:
----------------------------------------------------------------------
Requirement                                          |          Status
----------------------------------------------------------------------
SPDXVersion provided?                                |            True
DataLicense provided?                                |           False
DocumentName provided?                               |            True
Creator provided?                                    |            True
Created timestamp provided?                          |            True
SBOM Type provided?                                  |            True
All PackageNames provided?                           |            True
All PackageVersions provided?                        | False (279/452)
All PackageSuppliers provided?                       |   False (0/452)
All PackageDownloadLocations provided?               | False (172/452)
All PackageCopyrightTexts provided?                  |   False (0/452)
All PackageLicenseConcluded provided?                |   False (0/452)
All PackageLicenseDeclared provided?                 | False (451/452)
At least one license is not NOASSERTION?             | False (171/452)
All PackageChecksums provided? (RECOMMENDED)         | False (142/452)
All Package URLs (PURL) provided? (RECOMMENDED)      |   False (0/452)
Runtime dependency relationships exist?              |            True
All dependency targets exist as Package?             |            True
Transitive dependencies complete?                    |            True
Missing components as known unknowns?                |            True
----------------------------------------------------------------------

Mandatory Requirements: 10/18
Recommended Requirements: 0/2
Violations: 2199
Warnings: 800
```

Note: As of Sep. 2025 (Yocto 5.2)

PoC: Analyze Risks



Policy Engine (Current Choice):
OPA (Open Policy Agent)

- Open-source, general-purpose policy engine
- CNCF graduated project
- Widely used in cloud-native environments

Example Policies

Example Policy 1: Detecting GPL v3 Family Licenses

Policy Code:

```
package license

licenses_gplv3_family := [
    "GPL-3.0-only",
    "GPL-3.0-or-later",
    "LGPL-3.0-only",
    "LGPL-3.0-or-later",
    "AGPL-3.0-only",
    "AGPL-3.0-or-later",
]

banned_license_gplv3[res] {
    some i
    pkg := input.packages[i]
    license_string := pkg.license_declared

    not is_invalid_license(license_string)
    license_tokens := tokenize_spdx(license_string)
    licence_to_check := license_tokens[_]
    contains(licenses_gplv3_family, licence_to_check)

    res := {
        "0:message": sprintf("%s is banned by project: GPLv3 Family", [licence_to_check]),
        "1:pkgName": pkg.name,
        "2:pkgVersion": pkg.version,
        "3:license": license_string
    }
}
```

Input JSON:

```
"packages": [
  {
    "name": "base-files",
    "version": "3.0.14",
    "license_declared": "GPL-2.0-only",
    "license_concluded": ""
  },
  {
    "name": "base-passwd",
    "version": "3.6.7",
    "license_declared": "GPL-2.0-only",
    "license_concluded": ""
  },
```

Result:

```
build@UM690:/home/ishii/depot/agl/automation_work/automation-playground$ opa eval --format=pret
ty --data policy/license.rego --input data/spdx3_agl-image-weston_normalized.json data.license.
banned_license_gplv3
{
  {
    "0:message": "GPL-3.0-only is banned by project: GPLv3 Family",
    "1:pkgName": "tar",
    "2:pkgVersion": "1.35",
    "3:license": "GPL-3.0-only"
  },
  {
    "0:message": "GPL-3.0-or-later is banned by project: GPLv3 Family",
    "1:pkgName": "kbd-keymaps-pine",
    "2:pkgVersion": "2.8.0",
    "3:license": "GPL-3.0-or-later"
  },
  {
    "0:message": "GPL-3.0-or-later is banned by project: GPLv3 Family",
    "1:pkgName": "libreadline8",
    "2:pkgVersion": "8.3",
    "3:license
  },
  {
    "0:message
    "1:pkgName
    "2:pkgVers
    "3:license
  },
```

Example Policy 2: Admin Check for Unknown Licenses

Base Policy:

```
licenses_osi_approved := [
  "0BSD",
  "AAL",
  "AFL-1.1",
  "AFL-1.2",
  "AFL-2.0",
  "AFL-2.1",
  "AFL-3.0",
  "AGPL-3.0",
  "AGPL-3.0-only",
  "AGPL-3.0-or-later",
  "APL-1.0",
  "APSL-1.0",
  "APSL-1.1",
  "APSL-1.2",
  "APSL-2.0",
  "Apache-1.1",
  "Apache-2.0",
  "Artistic-1.0",
  "Artistic-1.0-Perl",
  "Artistic-1.0-cl8",
  "Artistic-2.0",
  "BSD-1-Clause",
  "BSD-2-Clause",
  "BSD-2-Clause-Patent",
```

+

Product Specific Policy:

```
licenses_project_approved := [
    "BSD-4-Clause-UC",
]
```

```
not_approved_license[res] {
    some i
    pkg := input.packages[i]
    license_string := pkg.license_declared

    not is_invalid_license(license_string)
    license_tokens := tokenize_spdx(license_string)

    licence_to_check := license_tokens[_]
    not contains(licenses_osi_approved, licence_to_check)
    not contains(licenses_project_approved, licence_to_check)

    res := {
        "0:message": sprintf("%s is neither approved by OSI nor project", [licence_to_check]),
        "1:pkgName": pkg.name,
        "2:pkgVersion": pkg.version,
        "3:license": license_string
    }
}
```

Result:

```
build@UM690:/home/ishii/depot/agl/automation_work/automation-playground$ opa eval --format=pret
ty --data policy/license.rego --input data/spdx3_agl-image-weston_normalized.json data.license.
not_approved_license
{
  {
    "0:message": "FTL is neither approved by OSI nor project",
    "1:pkgName": "libfreetype6",
    "2:pkgVersion": "2.13.3",
    "3:license": "( FTL OR GPL-2.0-or-later ) AND MIT"
  },
  {
    "0:message": "GPL-1.0-or-later is neither approved by OSI nor project",
    "1:pkgName": "util-linux-swaponoff",
    "2:pkgVersion": "2.41.1",
    "3:license": "GPL-1.0-or-later AND GPL-2.0-only AND GPL-2.0-or-later AND LGPL-2.1-or-later
AND BSD-2-Clause AND BSD-3-Clause AND BSD-4-Clause-UC AND MIT AND EUPL-1.2"
  },
  {
    "0:message": "HPND-sell-variant is neither approved by OSI nor project",
    "1:pkgName": "libx11-compose-data",
    "2:pkgVersion": "1.8.4",
    "3:license": "MIT AND BSD-1-Clause AND HPND AND HPND-sell-variant AND ISC"
  },
  {
    "0:message": "HPND-sell-variant is neither approved by OSI nor project",
    "1:pkgName": "libxkbcommon0",
    "2:pkgVersion": "1.11.0",
    "3:license": "MIT AND MIT-open-group AND HPND AND HPND-sell-variant AND X11"
  },
```

BSD-4-Clause-UC was approved

THE LINUX FOUNDATION

OPENCHAIN

Next Steps

Policy Engine Options: OPA (Open Policy Agent) or ORT (OSS Review Toolkit)

- OPA: Conforma
- ORT: Eclipse Apoapsis, OpenChain
- Criteria: SPDX3 compatibility, Flexible Policy Implementation, Pipeline Integration, Shared practices, Ecosystem, ...

CVE/VEX Operations (Yocto-based)

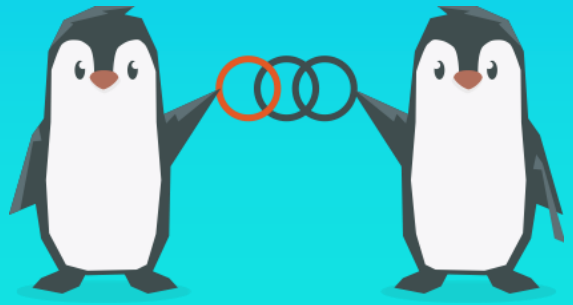
- cve-check, yocto-vex-check, sbom-cve-check, VulnScout, ...

Beyond Yocto

- SLSA in AOSP: [Open Source Summit NA 2026: Verification Toward Applying SLSA in Automotive IVI Software Development - Yuta Kiyoumi & Takashi Ninjouji, Honda Motor]

Thank you!

Repository:
https://github.com/automotive-grade-linux/automation-playground

Confluence:
English
Japanese

Discord:
https://discord.gg/ZztCaVeQVG